



Department for
Science, Innovation
& Technology

Security baselining for Salesforce Agentforce: A Secure By Design guide

Contents

Background	3
Security risk assessment and threat modelling	4
Data sensitivity	4
Secure architecture design	5
Zero-trust architecture	5
Least-privilege access	5
Network segmentation	5
Secure implementation and configuration	6
Identity and Access Management (IAM)	6
Secure AI guardrails	6
Secure API integration	6
Data protection and privacy controls	8
Encryption	8
Data minimisation	8
Testing and validation	9
Security testing	9
Controlled deployment	9
Monitoring and incident response	10
Logging	10
Governance and accountability	11
Security governance framework	11
More information	11

Background

[Secure By Design](#) is the UK Government's framework for improving the security of digital project delivery.

Artificial intelligence (AI) agents are increasingly used in digital public services to automate administrative processes, assist government staff and respond to citizen queries.

[Salesforce Agentforce](#) lets organisations deploy AI-driven agents capable of interacting with databases, knowledge systems and workflows.

In government environments, these agents might access sensitive data or operational workflows. In the course of your Secure By Design project, it is important to identify potential risks in products and find the best ways to manage them.

All UK government AI projects should follow the [AI Playbook for the UK Government](#), which requires projects to meet Secure By Design principles.

Security risk assessment and threat modelling

Secure by Design begins with identifying risks before systems are developed or deployed.

For Agentforce projects, organisations should build a [threat model](#) to identify potential vulnerabilities associated with AI agents. This should evaluate how AI agents interact or connect with:

- internal databases
- public- facing services, such as citizen service portals
- APIs
- external services, including other government bodies
- technical security services such as firewalls, Intrusion Prevention and Detection Systems (IPS and IDS), proxies, and logging and monitoring
- sources of identity, whether for external users or for internal users and sysadmins

Prompt injection should be considered a potential threat.

Bear in mind that AI agent deployments which mimic human workflows may reveal weaknesses in existing access restrictions. An agent may find data or functionality which team members have not used before. This means you can fix pre-existing but previously unknown overprivilege problems.

Data sensitivity

Government organisations must assess the sensitivity of data accessible to AI agents and put appropriate controls in place.

Data should already be classified according to the [government security classifications policy](#). Bear in mind the security classification level when planning the controls around the AI agent.

Secure architecture design

After risk assessment, the system architecture must be designed to minimise exposure to external threats.

Zero-trust architecture

When designing Agentforce systems, zero-trust architecture is a helpful guiding principle. This means explicit authorisation is required to access to data and services. The National Cyber Security Centre (NCSC) has [guidance on zero trust](#) architecture design principles.

Least-privilege access

Secure by Design requires strict application of the principle of least privilege.

Each AI agent should only have permissions necessary to perform its intended function.

You should pay particular attention to restricting access to sensitive systems such as payments or identity infrastructure. This should be driven by your [threat model](#).

Network segmentation

Where possible, AI agents should operate within segmented environments.

Segmentation controls may include:

- API gateways
- network firewalls
- service mesh policies

These controls ensure that an exploited agent cannot directly access critical infrastructure components.

Secure implementation and configuration

Secure by Design emphasises secure configuration during system implementation.

Identity and Access Management (IAM)

All administrative access to the platform should enforce strong identity controls, including:

- multi-factor authentication (MFA)
- role-based access control - including account life cycle controls such as access reviews and deprovisioning for leavers
- privileged access monitoring

Administrative privileges should be limited to authorised personnel.

Secure AI guardrails

AI systems require additional safeguards to prevent misuse.

Recommended controls include:

- prompt filtering
- response filtering
- capability restriction

Prompt filtering

Input validation mechanisms should detect malicious instructions designed to manipulate AI behaviour.

Response filtering

AI responses should be evaluated to ensure they do not reveal sensitive information.

Capability restriction

Agents should only be able to carry out a predefined set of permitted actions. As with traditional user access controls or firewall rules, the general principle should be: permit anything required by the design, block anything else. Different platforms enforce this in different ways (for example, through allow-lists and whitelists) and different levels of granularity.

Secure API integration

AI agents commonly interact with external systems using APIs.

Secure API configuration should include:

- [OAuth 2.0](#) authentication
- token validation
- rate limiting
- input sanitisation

External integrations should undergo security review before deployment.

Data protection and privacy controls

Government systems must comply with strict data protection requirements. In particular, systems processing personal data must comply with [UK GDPR](#).

Encryption

Sensitive data should be protected using strong encryption methods.

Security controls should include:

- encryption at rest using AES-256
- [TLS encryption](#) for data in transit
- secure storage of [encryption keys](#) - a good solution in a Software as a Service (SaaS) environment is likely to use a Key Management System (KMS)

Encryption should apply to databases, API communications and storage systems, including backups and logs.

Data minimisation

AI agents should only be permitted to access data required for their task.

Examples of data minimisation include:

- masking personal identifiers or [pseudonymisation](#)
- limiting access to specific database fields (such as column-level access controls)
- excluding sensitive documents from knowledge sources

This reduces the impact of potential data exposure.

Testing and validation

Secure by Design requires rigorous testing before systems are deployed in production environments.

Security testing

Testing activities should include:

- penetration testing
- access control validation
- prompt injection testing and prompt leakage
- model misuse
- API security testing

Security testing ensures vulnerabilities are identified before systems interact with live data. Traditional best practice involves using a dedicated test or pre-production environment and is still beneficial for modern AI projects.

Controlled deployment

Agentforce implementations should use these phased deployment stages:

1. Development testing
2. Pilot deployment
3. Gradual production rollout

This approach reduces operational risk and allows security teams to monitor system behaviour.

Monitoring and incident response

Secure by Design extends beyond deployment and requires ongoing operational security. To meet principle 5, [Build in detect and respond security](#), your service should be designed to:

- anticipate future security vulnerabilities and incidents
- enable detection and response

Logging

Systems should generate logs for all critical activities, including:

- authentication events
- data access
- agent actions
- system configuration changes

These logs should be protected against tampering, including by the same agent that they are monitoring.

A greater challenge may be integrating this with your operational security capabilities and making sure the log data can add value. You should take steps to ensure that security teams can:

- ingest logs
- correlate
- detect threats
- investigate incidents
- trigger alerts and automated responses

Governance and accountability

Secure by Design requires clear governance structures for managing system security.

AI agents should not independently make decisions that significantly affect citizens.

Examples of such decisions might include:

- approving government benefits
- issuing penalties
- modifying official records
- For more detailed guidance around the governance of AI, refer to the [AI playbook](#).

Security governance framework

Organisations should establish governance processes responsible for:

- approving AI deployments
- assessing security risks
- auditing system behaviour

These processes help maintain accountability and transparency in government systems.

More information

- [Secure by Design principles \(UK Government Security\)](#)
- [Secure by Design activities \(UK Government Security\)](#)